

WebPwn Advanced Pentest Report

Target: http://testphp.vulnweb.com

Date: 2026-05-12 15:50 | Generated by WebPwn Senior Pentest Module

Executive Summary

This report presents the findings of an advanced automated security assessment against http://testphp.vulnweb.com. The assessment utilized senior-level heuristics to identify critical vulnerabilities across OWASP Top 10 categories. A total of 12 security findings were recorded.

Severity	Count
CRITICAL	4
HIGH	5
MEDIUM	1
INFO	2

Detailed Security Findings

#1 [CRITICAL] sqli

Location: http://testphp.vulnweb.com/listproducts.php

CVSS Score: 9.8

Technical Details: SQL error triggered in param 'cat'

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Use parameterized queries / prepared statements.

#2 [CRITICAL] dir_bruteforce

Location: http://testphp.vulnweb.com/.git/config

CVSS Score: 9.1

Technical Details: Git repository exposed - source code leakage risk

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

[Block .git access in web server config.](#)

#3 [CRITICAL] auth_tester

Location: <http://testphp.vulnweb.com/login.php>

CVSS Score: 9.8

Technical Details: Successful login with admin:admin

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

[Enforce strong password policy. Implement MFA.](#)

#4 [CRITICAL] apk_analyzer

Location: <http://testphp.vulnweb.com>

CVSS Score: 9.0

Technical Details: AWS Access Key found in com/example/app/Config.java

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

[Never hardcode secrets. Use Android Keystore.](#)

#5 [HIGH] xss

Location: <http://testphp.vulnweb.com/search.php>

CVSS Score: 7.4

Technical Details: Payload reflected unescaped in response for param 'test'

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

[Encode all user-supplied output with context-aware encoding.](#)

#6 [HIGH] auth_tester

Location: <http://testphp.vulnweb.com/login.php>

CVSS Score: 8.8

Technical Details: JWT signed with weak secret: 'secret'

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Use long random secret (≥ 256 bits) or RS256.

#7 [HIGH] ssrf

Location: <http://testphp.vulnweb.com/redirect.php>

CVSS Score: 8.6

Technical Details: Server fetched internal AWS metadata endpoint

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Validate and whitelist allowed URL schemes/hosts.

#8 [HIGH] apk_analyzer

Location: <http://testphp.vulnweb.com>

CVSS Score: 7.4

Technical Details: android:debuggable=true allows runtime debugging

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Set android:debuggable=false in production builds.

#9 [HIGH] api_tester

Location: <http://testphp.vulnweb.com/api/users/2>

CVSS Score: 8.1

Technical Details: Resource ID 2 accessible without ownership check

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Implement object-level authorization checks.

#10 [MEDIUM] api_tester

Location: <http://testphp.vulnweb.com/api/login>

CVSS Score: 5.3

Technical Details: 20 rapid login requests sent without HTTP 429

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Implement rate limiting. Return 429 with Retry-After.

#11 [INFO] port_scanner

Location: testphp.vulnweb.com:3306

CVSS Score: N/A

Technical Details: Port 3306 is open (MySQL) — Banner: MySQL 5.7.30

[!] Attacker Impact / Scenario:

Exposed network services increase the attack surface. SSH, HTTP, and non-standard ports can be exploited for brute-force, service fingerprinting, and lateral movement.

[+] Strategic Remediation:

Restrict port access via firewall rules. Only expose necessary services. Harden SSH with key-based auth and disable root login.

#12 [INFO] tech_detector

Location: <http://testphp.vulnweb.com>

CVSS Score: N/A

Technical Details: Technology detected: Apache/2.4.7

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.
